



postMessage()

В этом упражнении показано, как небезопасные вызовы функции `postMessage()` в JavaScript могут привести к утечке конфиденциальной информации.

PRO

Средний

< 1 ч.

1298

Оранжевый значок

2 видео

Лаборатория

Разверните выделенный экземпляр для этого упражнения.

Развернуть

Во-первых, чтобы совершить атаку, нужно, чтобы жертва зашла на вашу страницу (убедитесь, что в вашей полезной нагрузке используется протокол `http`, а не `https`):

URL -адрес:

Submit

Чтобы отметить это упражнение как выполненное, вам нужно отправить ключ, который вы получите после его выполнения:

xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx

Отправить

Пожалуйста, не публикуйте никаких общедоступных отчетов о наших ПРОФЕССИОНАЛЬНЫХ упражнениях. Спасибо!

Видео



[postMessage\(\) - Введение](#)
03:50



[postMessage\(\): Эксплуатация](#)
09:26

Курс

Вам нравится эта бесплатная лаборатория?

Это лишь малая часть того, что вы получите с PentesterLab PRO! Получите доступ к сотням реальных лабораторий и видео, посвященных веб-хакингу, проверке кода и анализу уязвимостей CVE.

Разблокировать все лаборатории — стать PRO!



Внедрение [SameSite](#) в браузерах может ограничить возможности использования этой уязвимости. Жертва использует старый браузер, в котором не применяется [SameSite=Lax](#).

ВВЕДЕНИЕ

В этом курсе подробно рассматривается эксплуатация приложения с использованием `postMessage()` без указания пункта назначения. Используя эту уязвимость, вы сможете заставить [administrator](#) передавать конфиденциальную информацию на ваш сервер.

Эта задача основана на следующих материалах: [проблемы с postMessage](#) и [подводные камни postMessage](#).

Если вы чувствуете себя уверенно, можете попробовать выполнить это упражнение без курса, а затем вернуться к нему, чтобы ознакомиться с подробностями и советами. Если вы хотите выполнить упражнение самостоятельно, следуйте этим шагам:

- Изучите, как используется `postMessage()` и как работает аутентификация.
- Напишите вредоносную страницу, которая будет загружать уязвимую страницу.
- Используйте свою вредоносную страницу, чтобы получить доступ к значению.

JAVASCRIPT POSTMESSAGE()

Согласно [документации Mozilla](#):

«Метод `window.postMessage()` безопасно обеспечивает [cross-origin](#) связь между объектами [Window](#); например, между страницей и всплывающим окном, которое она породила, или между страницей и [iframe](#) встроенным в нее окном».

Однако если приложение использует файлы cookie и открытая страница отправляет конфиденциальную информацию на открывающую страницу без применения [targetOrigin](#), то вредоносная страница может получить доступ к этой конфиденциальной информации, заставив пользователя перейти к ней.

Чтобы избежать этой проблемы, серверная часть не должна использовать `*` в качестве второго аргумента `postMessage()` (`targetOrigin`).



JAVASCRIPT POSTMESSAGE()

Чтобы воспользоваться этой уязвимостью, вам нужно создать вредоносную HTML-страницу, которая будет открывать уязвимую страницу и отслеживать события, происходящие на ней. Вы можете использовать код уязвимого приложения, чтобы понять, как использовать `postMessage()`. Это позволит вам открыть уязвимую страницу с помощью прослушивателя, который будет использоваться для передачи информации на ваш сервер. Самый простой способ сделать это — создать тег `<img`, указывающий на ваш вредоносный сервер, и встроить передаваемые данные в URL.

ЗАКЛЮЧЕНИЕ

Это упражнение показало вам, как взломать страницу, использующую `postMessage()` без ограничений на `targetOrigin`. Это позволило открыть страницу так, как это сделало бы легитимное приложение, и использовать этот способ для передачи конфиденциальной информации на ваш сервер.

Надеюсь, вам понравилось учиться с PentesterLab.

< [ПРЕДЫДУЩАЯ СТРАНИЦА](#)
[Межсайтовый перехват WebSocket](#)

[ДАЛЕЕ](#)
[Почтовое сообщение\(\)](#) ||

[Exercises](#)

[Live Training](#)

[Blog](#)

[Glossary](#)

[Support](#)

[Merch](#)

© 2026 PentesterLab